

12-security-compliance-and-operations.md

Corevo Booking Platform

Säkerhet, Drift, GDPR och Operativa Rutiner

Version: 1.0

Introduktion

Detta dokument beskriver hur Corevo Booking Platform ska skyddas, övervakas, underhållas och drivas.

Många projekt fokuserar endast på funktioner.

Det leder ofta till problem senare.

En plattform som hanterar:

- kunddata
- bokningar
- betalningar
- personalinformation

måste byggas med säkerhet från början.

Målet är att skapa en plattform som:

- är säker
 - är stabil
 - är enkel att underhålla
 - kan återställas vid problem
 - kan växa utan att skapa kaos
-

Grundprinciper

Corevo ska följa fyra huvudprinciper.

Princip 1

Minsta möjliga åtkomst.

Ingen användare ska kunna se mer än vad som behövs.

Princip 2

Allt loggas.

Viktiga händelser ska kunna spåras.

Princip 3

Data ska kunna återställas.

Princip 4

Kunder ska kunna lita på plattformen.

Säkerhetsnivåer

Systemet delas upp i flera säkerhetsnivåer.

Nivå 1

Publik användare.

Ej inloggad.

Nivå 2

Kund.

Nivå 3

Frisör.

Nivå 4

Reception.

Nivå 5

Manager.

Nivå 6

Owner.

Nivå 7

Corevo Admin.

Nivå 8

Corevo Super Admin.

Autentisering

All autentisering ska ske centralt.

Kund

Magic Link

eller

OTP-kod

Personal

E-post + lösenord

Corevo Admin

Lösenord + tvåfaktor

Tvåfaktorsautentisering

Krav för:

Corevo Admin

Super Admin

Rekommendation

Även för salongsägare.

Lösenordspolicy

Minimilängd.

Starka lösenord.

Hashning.

Aldrig

Lagra lösenord i klartext.

Sessioner

Alla sessioner ska vara tidsbegränsade.

Exempel

Kund:

30 dagar

Personal:

7 dagar

Corevo Admin:

24 timmar

Rollbaserad åtkomst

Alla funktioner styrs av roller.

Exempel

Frisör:

Kan inte se Stripe.

Reception:

Kan inte ändra priser.

Manager:

Kan inte ändra Corevo-inställningar.

Tenant Isolation

Mycket viktig princip.

Regel

En tenant får aldrig kunna se en annan tenants data.

Exempel

Freshcut får aldrig kunna se:

Lifestyle

Barber House

annan kunddata

Verifiering

Ska ske på backend.

Inte frontend.

Audit Logs

Alla viktiga åtgärder loggas.

Exempel

Pris ändrat

Frisör skapad

Salong skapad

Kund raderad

Roll ändrad

Audit Log innehåller

Tid

Användare

IP

Åtgärd

Resultat

Säkerhetsloggar

Separata loggar.

Exempel

Misslyckad inloggning

Token-fel

Otillåten åtkomst

Rate Limiting

Skyddar mot attacker.

Exempel

Inloggning

Max antal försök

API

Max requests per minut

Filuppladdning

Måste begränsas.

Tillåtna format

jpg

png

webp

pdf

Blockera

exe

bat

js

php

Filscanning

Version 2.

HTTPS

Krav för hela plattformen.

Ingen trafik

Får gå okrypterad.

Dataskydd

Personuppgifter ska behandlas korrekt.

Exempel

Namn

Telefon

E-post

Bokningar

Känsliga uppgifter

Ska minimeras.

Regel

Samla endast in data som behövs.

GDPR

Corevo ska följa GDPR.

Kunden ska kunna

Begära export

Begära rättelse

Begära radering

Salongen ska kunna

Exportera kunddata

Anonymisera kunddata

Corevos roll

Vanligtvis personuppgiftsbiträde.

Salongens roll

Vanligtvis personuppgiftsansvarig.

Backup Strategi

Mycket viktig.

Dagligen

Databasbackup.

Veckovis

Full backup.

Månatlig

Arkivbackup.

Backup-lagring

Separat från produktionsmiljön.

Test av backup

Måste göras regelbundet.

Exempel

Återställ testmiljö.

Verifiera data.

Disaster Recovery

Plan för större problem.

Exempel

Databaskrasch

Serverfel

Felaktig release

Målsättning

Snabb återställning.

Driftövervakning

Systemet ska övervakas.

Exempel

Databas

API

Storage

Mail

Stripe

Hälsokontroller

Automatiska kontroller.

Exempel

Databas svarar

API svarar

Mail fungerar

Incidenthantering

När något går fel.

Steg 1

Identifiera.

Steg 2

Isolera.

Steg 3

Återställ.

Steg 4

Dokumentera.

Steg 5

Förhindra upprepning.

Release Process

Nya funktioner ska släppas kontrollerat.

Flöde

Utveckling

↓

Testmiljö

↓

Intern testning

↓

Produktion

Ingen direkt deploy

Till produktion.

Testmiljö

Separat miljö.

Syfte

Verifiera funktioner.

Undvika buggar.

Versionshantering

Alla större ändringar ska dokumenteras.

Exempel

v1.0

v1.1

v1.2

v2.0

Changelog

Alla releaser dokumenteras.

Driftansvar

Corevo ansvarar för:

Plattform

Databas

Hosting

API

Salongen ansvarar för:

Innehåll

Priser

Personal

Öppettider

Supportnivåer

Låg

Normal

Kritisk

Kritisk

Bokningar fungerar inte.

System nere.

Hög

Betalningar fungerar inte.

Normal

Designproblem.

Mindre buggar.

Låg

Önskemål.

Förbättringsförslag.

Dokumentation

Allt ska dokumenteras.

Exempel

API

Databas

Deployment

Backup

Support

Framtida Säkerhetsfunktioner

Single Sign-On

Passkeys

Avancerad loggning

SIEM

Intrångsdetektering

Definition av färdig modul

Modulen anses klar när:

- Roller fungerar
- Behörigheter fungerar
- Audit Logs fungerar
- Backup fungerar
- GDPR-processer finns
- Incidenthantering finns
- Releaseprocess finns
- Driftövervakning finns
- Tvåfaktorsautentisering finns för admins

Denna modul säkerställer att Corevo Booking Platform inte bara fungerar idag utan också kan drivas säkert och professionellt när plattformen växer och får fler kunder.